

CYBERSECURITY INTERNSHIP REPORT

WEEK 5 – TASK 16 (SOC)

INCIDENT RESPONSE PROCESS (NIST PHASES)

Submitted By	MANOJ
Role	Cyber Security Intern
Internship Organisation	TechBiz Security
Internship ID	TBS-INT-2026-518
Submitted Date	22 SEPT 2026

1. Introduction

This report documents the work carried out for Week 5, Task 16 of the Cyber Security Internship at TechBiz Security. The task focuses on the Incident Response (IR) process followed by analysts in a Security Operations Center (SOC) and on how an analyst applies a structured lifecycle when a security alert develops into a possible incident.

The activity covers the traditional six-phase incident response lifecycle specified in the internship task:

1. **Preparation**
2. **Detection & Analysis**
3. **Containment**
4. **Eradication**
5. **Recovery**
6. **Lessons Learned**

A structured incident response process matters because security incidents are time-sensitive and are usually handled under pressure. Without a defined process, alerts can be triaged inconsistently, evidence can be lost, containment decisions can be delayed or applied without authorisation, and the same weaknesses can be exploited again. A lifecycle-based approach gives analysts a common sequence of activities: prepare before incidents occur, identify and validate them, limit their impact, remove the cause, restore normal operations, and learn from the outcome so that the organisation is better prepared next time.

As part of the SOC learning activity, the mandatory TryHackMe room “Introduction to SIEM” was also completed. The room reinforced the Security Information and Event Management (SIEM) concepts that underpin alert investigation in a SOC, and it is documented in Sections 9 to 11 of this report.

1.1 Note on NIST Terminology

The six-phase terminology used in this report comes from the internship task specification. It is the traditional incident response lifecycle commonly taught to SOC analysts and associated with earlier NIST incident handling guidance. It is not the exact structure of the current NIST publication.

NIST SP 800-61 Rev. 2 (2012) describes the lifecycle in four phases: Preparation; Detection and Analysis; Containment, Eradication and Recovery; and Post-Incident Activity. The six-phase model separates the third phase into three stages and corresponds to Post-Incident Activity as Lessons Learned.

NIST SP 800-61 Rev. 3 (April 2025) supersedes Rev. 2. It aligns incident response recommendations with the functions of the NIST Cybersecurity Framework (CSF) 2.0 and treats incident response as part of overall cybersecurity risk management, rather than presenting the six-phase lifecycle as its structure. This report therefore uses the six phases only because the task requires them.

2. Objectives

The objectives of this task were to:

- Understand the Incident Response lifecycle.
- Understand the responsibilities of a SOC analyst during an incident.
- Understand short-term and long-term containment.
- Apply the Incident Response phases to a simulated malware-infection scenario.
- Understand when an L1 SOC analyst should escalate an incident to L2.

- Understand the role of SIEM in detection and analysis.
- Complete the mandatory TryHackMe Introduction to SIEM room.

3. Incident Response Lifecycle

The table below summarises each phase of the six-phase lifecycle, its purpose, and the activities a SOC analyst typically performs within it.

Phase	Description	SOC Analyst Activity
Phase 1 – Preparation	Establishing the people, processes and technology needed to handle incidents before they occur. This includes maintaining monitoring capability, deploying and tuning security tools, defining incident-response procedures and escalation paths, maintaining tested backups, keeping documentation and asset information current, and training analysts.	• Confirms that required log sources are reporting to the SIEM. • Becomes familiar with playbooks, escalation contacts and reporting templates. • Takes part in training and tabletop exercises.
Phase 2 – Detection & Analysis	Identifying possible incidents and determining what has happened. Alerts are reviewed, relevant logs and events are examined, suspicious activity is validated, and a decision is made on whether the alert represents a genuine incident. The likely scope and impact are then assessed.	• Reviews SIEM alerts and their supporting events. • Checks authentication, endpoint and network logs for related activity. • Separates false positives from true incidents. • Records findings, assigns severity and assesses scope.
Phase 3 – Containment	Limiting the spread and impact of the incident by isolating the affected system so that it cannot spread further or communicate with malicious infrastructure. Short-term containment applies immediate actions, such as isolating the endpoint from the network, to stop the activity quickly. Long-term containment applies temporary controls that keep the threat contained and the business running while deeper investigation and remediation are carried out.	• Isolates the affected system where authorised. • Preserves relevant evidence before making changes. • Documents every action taken and when it was taken. • Coordinates with L2 and IT teams on longer-term controls.
Phase 4 – Eradication	Removing the cause of the incident. This includes identifying and removing malware and malicious processes, eliminating persistence mechanisms, addressing indicators of compromise, and correcting compromised credentials or insecure configurations where these are identified.	• Supports identification of malicious files, processes and persistence. • Compiles indicators of compromise for wider searching in the SIEM. • Flags credentials or configurations that need to be reset or corrected.

Phase	Description	SOC Analyst Activity
Phase 5 – Recovery	Returning affected systems to normal operation from a known-good state. Security is validated before reconnection, systems are reconnected when appropriate, and they are monitored for recurring suspicious activity.	• Confirms the system meets the agreed security baseline before reconnection. • Monitors the system in the SIEM for a defined period after recovery. • Reports any recurrence promptly.
Phase 6 – Lessons Learned	Reviewing the incident after it is resolved. This includes reviewing the timeline, identifying gaps in detection and response, documenting findings, improving detection rules and security controls, and updating procedures or training.	• Contributes to the incident review and timeline. • Notes missed or late detections and suggests rule improvements. • Updates documentation and playbooks based on outcomes.

4. SOC Analyst Role During an Incident

An L1 SOC analyst is usually the first person to see and assess an alert, so the quality of the initial triage strongly affects the rest of the incident. The responsibilities below were studied as part of this task and are presented as the expected duties of an L1 analyst, not as activities performed on a real compromised system.

- **Monitoring SIEM alerts.** Watching the SIEM alert queue and picking up new alerts promptly.
- **Reviewing and validating alerts.** Checking whether an alert is supported by evidence or is likely to be a false positive, using the alert rule logic and the related events.
- **Checking relevant logs.** Looking at authentication, endpoint, network and system logs that relate to the affected user, host or service.
- **Prioritising alerts.** Ranking alerts by severity, asset criticality and the strength of the available evidence so that the most serious activity is handled first.
- **Performing initial investigation.** Establishing what happened, which assets are involved and whether the activity is still continuing.
- **Collecting and documenting evidence.** Recording relevant log entries, alert details and observations in a way that preserves their integrity and supports later analysis.
- **Following incident-response procedures.** Working within approved playbooks and procedures rather than improvising, so that actions are consistent and auditable.
- **Performing authorised initial containment.** Carrying out initial containment steps, such as network isolation of an endpoint, only where the procedures authorise the analyst to do so.
- **Maintaining accurate documentation.** Keeping a clear, time-ordered record of findings, decisions and actions in the ticket or case record.
- **Escalating when required.** Passing the incident to L2 when it exceeds L1 authority, knowledge or investigation scope, with enough detail for the next analyst to continue without repeating the work.

5. Containment: Short-Term vs Long-Term

Containment aims to stop an incident from getting worse while keeping the evidence and the organisation's operations as intact as possible. It is normally handled in two stages.

5.1 Short-Term Containment

Short-term containment consists of fast, immediate actions taken as soon as an incident is confirmed or strongly suspected:

- Isolate the affected endpoint.
- Prevent further network communication to and from the endpoint.
- Stop the immediate spread of the activity where the analyst is authorised to act.
- Preserve relevant evidence before it is lost or altered.

5.2 Long-Term Containment

Long-term containment keeps the threat under control for the period in which the root cause is investigated and remediation is prepared:

- Apply temporary security controls.
- Restrict affected services or accounts where appropriate.
- Maintain controlled access while deeper investigation and remediation are performed.
- Reduce the chance of reinfection while the incident is being resolved.

5.3 Key Difference

Short-term containment is about speed. It stops the damage that is happening now, even if the measure is blunt, such as cutting a workstation off from the network. Long-term containment is about stability. It replaces those emergency measures with more precise and sustainable controls, so that affected assets can be managed safely, and in some cases used in a limited way, until eradication and recovery can take place. Short-term actions are usually taken by the first responder within minutes, whereas long-term measures are typically planned with L2 analysts, system owners and IT teams.

6. Simulated Malware-Infection Scenario

SIMULATED / TABLETOP SCENARIO

6.1 Scenario Description

A SIEM alert indicates that a suspicious executable was launched on a Windows workstation. The same workstation also shows unusual outbound network traffic.

6.2 Scope and Limitations

This scenario was created for learning and documentation purposes only. No malware was executed, and no real compromised system, real alert or real log data was investigated. For this reason, the scenario deliberately does not name a malware family, host, user, IP address, file hash, timestamp, command or specific SIEM alert. Section 7 describes what a SOC analyst would do at each phase and what should be in place. It does not report investigation results.

7. Six-Phase Scenario Walkthrough

The following sections apply the six phases to the simulated scenario in Section 6. All statements describe expected analyst actions in a tabletop context.

7.1 Preparation

The response to this scenario depends on what exists before the alert appears. The following should already be in place:

- **Monitoring and SIEM visibility.** Endpoint and network telemetry from Windows workstations, including process creation and outbound connection data, reaching the SIEM.
- **Detection content.** Detection rules or use cases that can flag suspicious executable launches and unusual outbound traffic.
- **Incident-response procedures.** An approved malware-incident playbook, defined severity levels, and clear escalation contacts and authority limits for L1 analysts.
- **Backups.** Tested backups and known-good system images so that the workstation can be restored.
- **Analyst readiness.** Analysts trained on the SIEM, the playbook and the documentation format, ideally through prior exercises.

7.2 Detection & Analysis

On receiving the alert, the L1 analyst would work through the following steps. No investigation results are given because the scenario is simulated.

- **Review the SIEM alert.** Read the alert details, the rule that triggered it and the affected asset, and check whether similar alerts have recently occurred.
- **Examine related endpoint and network events.** Search the SIEM for endpoint events on the same workstation around the time of the alert, such as process creation, logon activity and file activity, to build a timeline.
- **Investigate the suspicious executable.** Establish the file location, the parent process that launched it, the user context it ran under, and whether the file is signed, known or recently introduced. Reputation checks would be done using approved tools and procedures.
- **Review the unusual outbound traffic.** Identify the destination, port, volume and frequency of the traffic, and whether it matches the workstation's normal behaviour or known business services.
- **Determine whether it is a true incident.** Combine the evidence from the executable and the network activity to decide whether the alert is a false positive, a benign but unusual activity, or a true security incident.
- **Assess potential scope and impact.** Consider whether other hosts show the same behaviour, whether privileged accounts or sensitive data are involved, and what the business impact could be. This assessment informs severity and any escalation decision.

7.3 Containment

Short-term

- Isolate the affected workstation from the network, using the approved endpoint isolation method where the analyst is authorised.
- Prevent further suspicious communication, for example by blocking the observed destination if the procedures allow this.
- Preserve relevant evidence, including the alert record, related logs and details of the file and process, before any remediation changes are made.

Long-term

- Apply appropriate temporary controls, such as additional network restrictions or heightened monitoring of the workstation and related accounts.

- Restrict affected services or accounts when required, for example by requiring credential resets or limiting access if account misuse is suspected.
- Maintain containment while the investigation continues, and review it regularly so that it is neither lifted too early nor kept longer than necessary.

7.4 Eradication

Once the incident is understood well enough, the malicious activity would need to be removed from the environment. This would involve identifying and removing the malicious executable and any related processes, and looking for persistence mechanisms that would let the activity return after a restart or removal. Where the investigation shows that credentials or configurations were compromised or weakened, these would be reset or corrected. Indicators identified during the investigation would be searched for across other systems in the SIEM to confirm that the activity is not present elsewhere. In a live incident, these actions would generally be carried out or supervised by L2 or the system owners. Eradication was not performed in this simulated scenario.

7.5 Recovery

Recovery would return the workstation to a known-good state, normally by rebuilding it from a trusted image or restoring it from clean backups, depending on the severity of the incident. Before the system is reconnected, its security would be validated, for example by confirming that patches, endpoint protection and required configuration are in place. The workstation would then be reconnected when appropriate and monitored in the SIEM for a defined period for a return of the original activity or other suspicious behaviour. No workstation was recovered in this simulated scenario.

7.6 Lessons Learned

After closure, a review would examine the incident timeline from first activity to resolution, and would ask the following questions:

- How effective was the response, and did each team act within the procedures?
- Were there detection gaps, and could the activity have been identified earlier or more reliably?
- Were containment decisions timely, appropriate and properly authorised?
- Which security controls, such as application control, network filtering or endpoint protection, could reduce the likelihood or impact of a similar event?
- Which detection rules, SOC procedures, playbooks and training materials should be updated?

The outcomes would be documented and assigned to owners so that improvements are actually carried out.

8. L1 to L2 Escalation

L1 analysts are expected to triage and act within defined limits. They should escalate to L2 when an incident needs deeper investigation, elevated privileges, specialised expertise, or actions outside the authority of the L1 role. Escalating early and with good documentation is better than delaying while trying to resolve an incident alone.

Examples of conditions that should prompt escalation include:

- Confirmed or suspected system compromise.
- Involvement of privileged or administrative accounts.
- Suspected lateral movement.
- Possible data exfiltration.

- Multiple affected systems.
- Significant business impact.
- Critical or sensitive assets being affected.
- Inability to safely contain the incident at L1.
- Investigation requirements that exceed L1 capability or authority.

8.1 Escalation Note

The note below shows the format an L1 analyst would use to escalate the simulated scenario. Items in square brackets are placeholders that would be completed from the SIEM and case record in a live incident. They are intentionally not filled in because this is a tabletop exercise.

To	L2 SOC Analyst
From	L1 SOC Analyst
Subject	Escalation of suspected malware activity on a Windows workstation (simulated scenario)
Reference	[Alert ID] [Affected asset] [Time of first alert]
Summary	A SIEM alert indicated that a suspicious executable was launched on a Windows workstation. The same workstation showed unusual outbound network traffic. Initial triage could not rule out compromise of the endpoint.
Actions taken at L1	Alert and related endpoint and network events reviewed. Evidence and observations recorded. Workstation isolated from the network where authorised. [Any additional actions taken]
Reason for escalation	Suspected system compromise combined with unexplained outbound communication. Host-level analysis, assessment of possible spread to other systems and decisions on eradication and recovery are beyond L1 scope and authority.
Requested action	L2 to take ownership of the investigation, confirm the scope of the incident, direct long-term containment and advise on eradication and recovery.

9. SIEM and SOC Learning

A Security Information and Event Management (SIEM) platform is one of the central tools of a SOC and supports several phases of the incident response lifecycle, particularly Preparation and Detection & Analysis. Its main contributions are as follows:

- **Centralised log collection.** Logs from endpoints, servers, network devices and applications are brought into one place so that analysts do not have to check each system separately.
- **Log analysis.** Collected logs are normalised and made searchable, allowing analysts to query for specific users, hosts, processes or connections.
- **Correlation of security events.** Events from different sources are linked, so that a process launch on an endpoint and unusual outbound traffic from the same host can be seen as one related pattern.
- **Alert generation.** Rules and thresholds generate alerts when defined conditions are met, which is how many incidents first reach the SOC.
- **Detection of suspicious activity.** Known-bad patterns and deviations from normal behaviour can be flagged for review.

- **Investigation support.** Searchable historical data helps analysts build timelines and understand the extent of an incident.
- **Incident documentation and monitoring.** SIEM alerts, cases and dashboards provide a record of what was detected and how it was handled, and they show whether the environment remains quiet after recovery.

These concepts relate directly to the simulated scenario in Section 7, where the initial alert, the search for related endpoint and network events and the post-recovery monitoring all depend on SIEM capability. The TryHackMe Introduction to SIEM room, described in Section 10, was used to reinforce this foundation. The SIEM concepts in this section are drawn from the learning activity and general SOC practice. The simulated scenario was not generated from alerts in a SIEM lab environment.

10. TryHackMe – Introduction to SIEM

The mandatory TryHackMe room “Introduction to SIEM” was completed as part of the SOC learning activity. According to the room page, it teaches the fundamentals of SIEM and explores its features and functionality. The page lists an estimated duration of 120 minutes.

The supplied screenshot (Figure 1) is the only evidence used for this section. It shows the following:

- The room title, “Introduction to SIEM”, on the TryHackMe room page.
- The completion indicator reading “Room completed: 100%”.
- The list of tasks in the room, each displaying a completed status marker.

The task titles visible in the screenshot are listed below. The first five tasks are visible, and the fifth is partially cut off at the bottom edge of the capture.

Task	Title	Status shown
Task 1	Introduction	Completed
Task 2	Logs Everywhere, Answers Nowhere	Completed
Task 3	Why SIEM?	Completed
Task 4	Log Sources and Ingestion	Completed
Task 5	Alerting Process and Analysis	Completed (partially visible)

The screenshot does not display individual task answers, flags, commands or lab outputs, so none are reproduced or described here.

11. Evidence / Screenshot

Figure 1 is the unaltered screenshot supplied as evidence of completion of the room. Figure 2 is an enlarged crop of the same screenshot, included only to make the room title and the completion status easier to read.

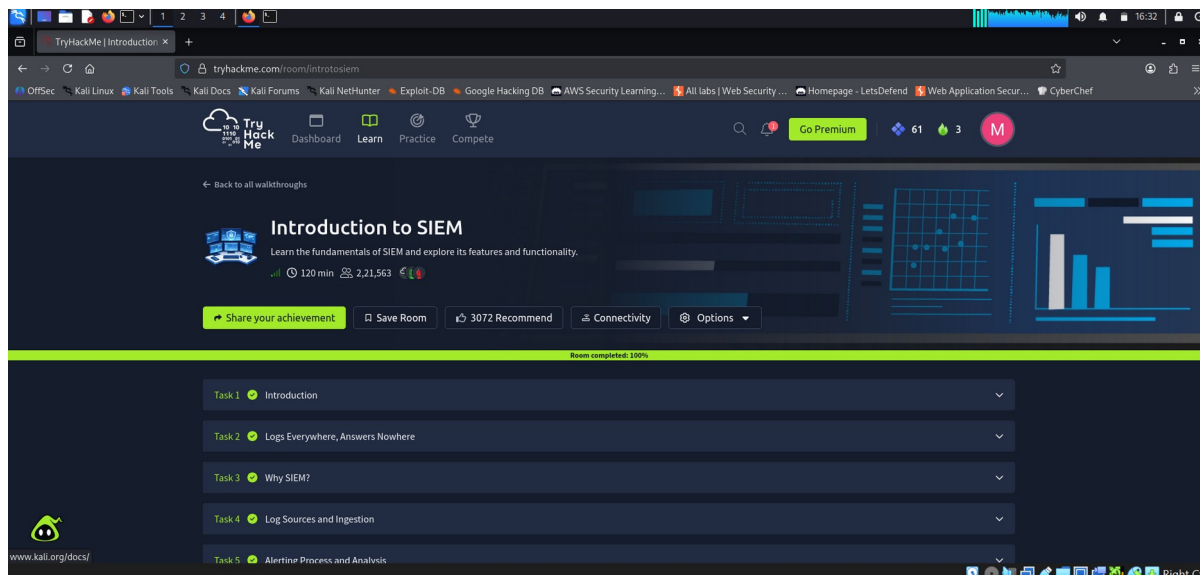


Figure 1: TryHackMe – Introduction to SIEM room showing 100% completion.

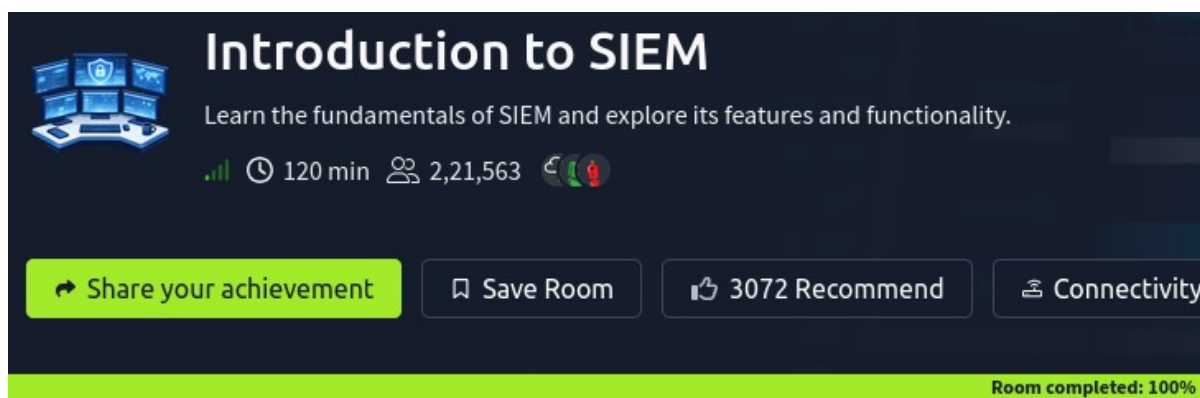


Figure 2: Enlarged detail of Figure 1 showing the room title and the “Room completed: 100%” status.

12. Practical Learning Outcome

The task gave a working understanding of how a SOC handles security incidents. The table below lists each learning outcome and states how it was achieved, so that theoretical learning, the simulated scenario and the practical room completion are clearly separated.

Learning outcome	Basis
Understanding the structured Incident Response lifecycle.	Theoretical learning
Understanding SOC analyst responsibilities.	Theoretical learning
Understanding containment strategies.	Theoretical learning
Understanding the difference between short-term and long-term containment.	Theoretical learning

Learning outcome	Basis
Understanding how a malware incident can be handled through the IR lifecycle.	Simulated / tabletop scenario
Understanding L1 to L2 escalation.	Theoretical learning, applied in the simulated scenario
Understanding the role of SIEM in security monitoring and incident investigation.	Theoretical learning, supported by the TryHackMe room
Completing the TryHackMe Introduction to SIEM learning activity.	Practical activity, evidenced by Figure 1

The only practical activity with supporting evidence is the completion of the TryHackMe room. The malware-infection walkthrough is a tabletop exercise, and no real incident was investigated.

13. Conclusion

This task provided an understanding of how SOC teams approach security incidents through a structured Incident Response process. The six-phase scenario showed how an incident can progress from preparation and detection through containment, eradication, recovery and lessons learned, and how each phase builds on the previous one. Separating short-term and long-term containment showed how an analyst can act quickly to limit damage while still preserving evidence and supporting a thorough investigation.

The task also highlighted the importance of timely escalation from L1 to L2 when an incident exceeds L1 authority or investigation capability, supported by clear and accurate documentation. Completion of the TryHackMe Introduction to SIEM room provides supporting learning evidence for the role of SIEM in log collection, correlation, alerting and investigation. Together, these activities have strengthened the theoretical foundation needed for working as an L1 SOC analyst.

14. References

- [1] National Institute of Standards and Technology. NIST Special Publication 800-61 Revision 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. April 2025. <https://doi.org/10.6028/NIST.SP.800-61r3>
- [2] National Institute of Standards and Technology. NIST Special Publication 800-61 Revision 2, Computer Security Incident Handling Guide. August 2012. <https://doi.org/10.6028/NIST.SP.800-61r2>
- [3] TryHackMe. Introduction to SIEM (room). <https://tryhackme.com/room/introtoSIEM>